

Password & Access Control Policy

Week 4 GRC Portfolio Project

Company

ABC Solutions Pvt. Ltd.

Prepared By

Durva Amin

Version

1.0

Date

23 August 2026

Review Date

23 August 2027

Document Control

Field	Details
Document Title	Password & Access Control Policy
Document Owner	Information Security
Version	1.0
Status	Draft
Effective Date	August 2026
Review Frequency	Annual
Classification	Internal
Approved By	Management

Table of Contents

Document Control	2
Purpose	6
Scope	6
Policy Objectives	6
Roles & Responsibilities	6
Password Requirements	7
Password Length	7
Password Complexity	7
Password Reuse	7
Password Sharing	7
Password Storage	7
Compromised Passwords	7
Multi-Factor Authentication (MFA)	8
MFA Requirement	8
Authentication Factors	8
MFA Protection	8
Authentication & Authorization	8
Authentication	8
Authorization	8
Access Approval	8
Least Privilege	9
Access Based on Job Responsibilities	9
Minimum Required Access	9
Periodic Access Review	9
Example	9
Need to Know	9
Access to Information	9
Approval	10
Periodic Review	10
Example	10
Privileged Accounts	10
Privileged Access	10
Separate Administrative Accounts	10
MFA for Privileged Accounts	10

Monitoring	10
Periodic Review	10
Example	11
Password Storage & Protection	11
Password Storage	11
Password Transmission	11
Password Manager	11
Credential Protection	11
Access Review	12
Periodic Access Review	12
Manager Review	12
Access Removal	12
Privileged Access Review	12
Security Awareness	12
Password Security Awareness	13
Phishing Awareness	13
MFA Awareness	13
Reporting Security Incidents	13
Exceptions	13
Exception Request	13
Exception Approval	13
Exception Duration	13
Exception Review	14
Policy Violations	14
Examples of Violations	14
Reporting	14
Investigation	14
Disciplinary Action	14
Monitoring & Review	15
Policy Review	15
Access Monitoring	15
Compliance Monitoring	15
Policy Updates	15
Access Control Matrix	15
New Employee Access Scenario	16

Scenario	16
Access Request	16
Access Decision.....	16
Security Principles Applied	16
Version History	17
References	17

Purpose

The purpose of this Password & Access Control Policy is to establish minimum requirements for creating, managing, protecting, and reviewing user passwords and access to ABC Solutions Pvt. Ltd. information systems. The policy is intended to reduce the risk of unauthorised access, account compromise, and misuse of company information and systems.

Scope

This policy applies to all employees, contractors, interns, and other authorised users who access ABC Solutions Pvt. Ltd. information systems, applications, networks, and company data. It covers password management, authentication, authorisation, multi-factor authentication, access control, privileged accounts, and periodic access reviews.

Policy Objectives

The objectives of this policy are to establish consistent password and access control practices and reduce the risk of unauthorised access to company systems and information.

- Establish minimum password requirements for all user accounts.
- Require multi-factor authentication for applicable systems and accounts.
- Ensure users receive only the access required to perform their job responsibilities.
- Protect privileged accounts from unauthorised use.
- Require periodic review of user access and privileges.
- Reduce the risk of password compromise, unauthorised access, and misuse of company resources.
- Promote secure password and access management practices among employees.

Roles & Responsibilities

The following roles are responsible for implementing, maintaining, and following the requirements of this Password & Access Control Policy.

Role	Responsibility	Example
Management	Approves the policy and supports its implementation.	Approving the Password & Access Control Policy.
Information Security	Defines security requirements and monitors compliance with the policy.	Reviewing access controls and security requirements.
IT / System Administrators	Create, modify, and disable accounts and manage technical access controls.	Granting system access to an approved employee.
Managers	Approve access based on an employee's job responsibilities.	Approving Finance system access for a Finance employee.
Employees / Users	Follow password and access control requirements and protect their credentials.	Using unique passwords and reporting suspected account compromise.

Password Requirements

All users must follow the minimum password requirements established by ABC Solutions Pvt. Ltd. Passwords must be sufficiently strong, unique to each account, and protected from unauthorised disclosure or use.

Password Length

Passwords must be at least 12 characters long. Longer passwords or passphrases are encouraged where supported by the system.

Password Complexity

Passwords should use a combination of uppercase letters, lowercase letters, numbers, and special characters where supported by the system.

Password Reuse

Users must not reuse the same password across company accounts or between company and personal accounts.

Password Sharing

Passwords must not be shared with other users, written in publicly accessible locations, or communicated through insecure channels.

Password Storage

Users should store passwords only in approved password management solutions. Passwords must not be stored in plain-text documents, spreadsheets, or unsecured notes.

Compromised Passwords

Users must immediately report any suspected password compromise and change the affected password in accordance with the organisation's incident reporting process.

Requirement	Minimum Standard	Purpose
Password Length	Minimum 12 characters	Reduce password guessing risk
Password Complexity	Use varied character types where supported	Increase password strength
Password Reuse	Do not reuse passwords	Limit impact of credential compromise
Password Sharing	Prohibited	Prevent unauthorised credential use
Password Storage	Use approved password manager	Protect stored credentials
Compromised Password	Report and change immediately	Reduce account compromise risk

Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) requires users to provide more than one form of verification before accessing a system or account. MFA provides an additional layer of security if a password is compromised.

MFA Requirement

MFA should be enabled for systems and accounts that support it, particularly for remote access, privileged accounts, and systems containing sensitive information.

Authentication Factors

Authentication factors can include something the user knows, such as a password; something the user has, such as a security token or mobile device; and something the user is, such as a biometric characteristic.

MFA Protection

Users must not approve unexpected authentication requests or share MFA codes with another person. Suspected MFA compromise must be reported immediately.

Authentication Factor	Example
Something you know	Password or PIN
Something you have	Mobile device or security token
Something you are	Fingerprint or facial recognition

Authentication & Authorization

Authentication and authorisation are separate security processes. Authentication verifies the identity of a user, while authorisation determines what an authenticated user is permitted to access or perform.

Authentication

Users must be authenticated before being granted access to company systems and resources. Authentication mechanisms may include passwords, MFA, security tokens, or biometric methods, depending on the system.

Authorization

Access permissions must be assigned according to the user's job responsibilities and approved access requirements. Users must not receive permissions beyond what is necessary for their assigned responsibilities.

Access Approval

Access to company systems must be approved by the appropriate manager or system owner before IT or system administrators provision the requested access.

Security Process	Meaning	Example
Authentication	Verifies who the user is.	Logging in with a password and MFA.
Authorization	Determines what the authenticated user can access.	A Finance employee can access approved financial systems.

GRC Relevance: Separating authentication from authorisation helps organisations control access consistently and reduce the risk of unauthorised access to information and systems.

Least Privilege

The principle of least privilege requires users to receive only the minimum level of access necessary to perform their assigned job responsibilities. Access should not be granted beyond what is required for legitimate business needs.

Access Based on Job Responsibilities

User access must be based on the user's role and business responsibilities. Access requests should be reviewed and approved before permissions are granted.

Minimum Required Access

Users should receive only the permissions required to perform their assigned tasks. Unnecessary administrative or elevated privileges must not be granted.

Periodic Access Review

User access and privileges should be reviewed periodically to identify and remove unnecessary permissions.

Example

An HR employee may require access to employee records but does not require access to the Finance department's financial systems. Granting only the required HR access follows the principle of least privilege.

GRC Relevance: Least privilege reduces the potential impact of compromised accounts and helps organisations demonstrate that access is appropriately restricted according to business requirements.

Need to Know

The need-to-know principle requires users to access information only when that information is necessary for their assigned job responsibilities. Having access to a system does not automatically mean that a user should have access to all information within that system.

Access to Information

Access to sensitive or confidential information must be limited to users who require the information to perform legitimate business responsibilities.

Approval

Access to information should be approved by the appropriate manager or information owner before it is granted.

Periodic Review

Access to sensitive information should be reviewed periodically to identify and remove access that is no longer required.

Example

A Finance employee may need access to payroll information to perform payroll-related duties. An employee from the Operations department does not require access to the same information. Restricting payroll information to authorised Finance personnel follows the need-to-know principle.

GRC Relevance: The need-to-know principle helps protect sensitive information by ensuring that access is limited to users with a legitimate business requirement.

Privileged Accounts

Privileged accounts have elevated permissions that allow users to perform administrative or security-sensitive actions on company systems. Because these accounts can have a significant impact on systems and data, they require additional protection and monitoring.

Privileged Access

Privileged access must be granted only to authorised personnel who require elevated permissions for their job responsibilities. Access must be approved before privileges are assigned.

Separate Administrative Accounts

Where technically feasible, administrators should use separate accounts for administrative activities and normal day-to-day activities. Administrative accounts should not be used for routine tasks such as general web browsing or email.

MFA for Privileged Accounts

Multi-Factor Authentication must be enabled for privileged accounts where supported by the system.

Monitoring

Privileged account activity should be logged and monitored to help identify unauthorised or suspicious administrative actions.

Periodic Review

Privileged accounts and their assigned permissions should be reviewed periodically. Unnecessary or inactive privileged accounts must be disabled or removed.

Example

An IT administrator may require administrative privileges to configure company servers. A regular employee should not receive the same privileges because they are not required for normal job responsibilities.

GRC Relevance: Controlling privileged accounts supports least privilege, segregation of duties, access governance, monitoring, and accountability.

Password Storage & Protection

Passwords are sensitive authentication information and must be protected from unauthorised access, disclosure, and misuse. Passwords should not be stored or transmitted in plain text.

Password Storage

Systems must not store user passwords in plain-text form. Passwords should be securely protected using appropriate cryptographic password-hashing mechanisms.

Password Transmission

Passwords must not be transmitted through insecure or unprotected communication channels. Secure communication mechanisms should be used when authentication information is transmitted.

Password Manager

Users should use an organisation-approved password manager to securely store and manage passwords when required. Passwords must not be stored in unprotected text files, spreadsheets, or other unsecured locations.

Credential Protection

Users must protect passwords and other authentication credentials from unauthorised disclosure. Suspected credential compromise must be reported promptly to the appropriate IT or Information Security team.

Protection Measure	Requirement
Password Storage	Do not store passwords in plain text.
Password Hashing	Use appropriate password-hashing mechanisms.
Secure Transmission	Protect authentication information during transmission.
Password Manager	Use an approved password manager where applicable.
Credential Disclosure	Do not share passwords or authentication credentials.

GRC Relevance: Proper password protection reduces the risk of credential theft and supports the organisation's requirements for protecting authentication information.

Access Review

User access must be reviewed periodically to ensure that permissions remain appropriate for current job responsibilities. Unnecessary, excessive, or outdated access must be identified and removed.

Periodic Access Review

User accounts and access permissions should be reviewed at least annually and when significant changes occur, such as a change in job role, transfer to another department, or termination of employment.

Manager Review

Managers should review and confirm that their employees have only the access required for their current responsibilities.

Access Removal

Access that is no longer required must be removed or modified promptly. User accounts belonging to employees who leave the organisation must be disabled according to the organisation's offboarding process.

Privileged Access Review

Privileged accounts and elevated permissions should receive additional review to confirm that administrative access remains necessary and authorised.

Review Area	Responsible Role	Review Activity
User Access	Manager	Confirm employee access matches current job responsibilities.
Department Changes	Manager / IT	Update or remove access when an employee changes roles or departments.
Terminated Users	IT / System Administrator	Disable accounts and remove access according to the offboarding process.
Privileged Accounts	Information Security / IT	Review elevated permissions and confirm that administrative access remains necessary and authorized.

GRC Relevance: Periodic access reviews provide evidence that access is being governed and help reduce the risk of excessive, outdated, or unauthorised permissions.

Security Awareness

All users must understand and follow the organisation's password and access control requirements. Security awareness helps employees recognise common credential-related risks and understand their responsibilities for protecting company accounts and information.

Password Security Awareness

Users should be trained on secure password practices, including using unique passwords, protecting credentials, avoiding password sharing, and using approved password management solutions.

Phishing Awareness

Users should be trained to recognise suspicious emails, messages, login pages, and other attempts to obtain authentication credentials. Suspicious requests for passwords, MFA codes, or other authentication information must be reported.

MFA Awareness

Users should understand that MFA codes and authentication requests are sensitive security information. Unexpected MFA requests must not be approved without verifying the associated login activity.

Reporting Security Incidents

Users must promptly report suspected password compromise, phishing attempts, unauthorised access, or other security incidents to the appropriate IT or Information Security team.

Awareness Topic	Employee Responsibility
Password Security	Protect passwords and use approved password management practices.
Phishing	Identify and report suspicious messages or login requests.
MFA	Protect MFA codes and report unexpected authentication requests.
Security Incidents	Report suspected credential compromise or unauthorised access promptly.

GRC Relevance: Security awareness helps ensure that employees understand their responsibilities and supports the organisation's overall access-control requirements.

Exceptions

Exceptions to this policy may be permitted when a documented business or technical requirement prevents a control from being implemented as specified. Exceptions must be formally reviewed and approved before the exception is implemented.

Exception Request

The person requesting an exception must document the reason, affected system or process, requested exception, potential risks, and proposed compensating controls where applicable.

Exception Approval

Exceptions must be reviewed by Information Security and approved by the appropriate management authority before implementation.

Exception Duration

Exceptions should be granted for a defined period and must include an expiry or review date. Permanent exceptions should be avoided unless formally justified and approved.

Exception Review

Approved exceptions should be reviewed periodically to determine whether the original business or technical requirement still exists and whether the exception can be removed.

Exception Requirement	Description
Business Justification	Document why the policy requirement cannot be followed.
Risk Assessment	Identify the risks created by the exception.
Compensating Controls	Define alternative controls where appropriate.
Approval	Obtain approval from Information Security and appropriate management.
Expiry / Review Date	Define when the exception will expire or be reviewed.

GRC Relevance: A formal exception process ensures that deviations from security requirements are documented, risk-based, approved, and periodically reviewed.

Policy Violations

Failure to comply with this Password & Access Control Policy may increase the risk of unauthorised access, data exposure, or misuse of company systems. Policy violations should be reported, investigated, and handled according to the organisation's applicable procedures.

Examples of Violations

Examples of policy violations include sharing passwords, intentionally bypassing access controls, using unauthorised accounts, attempting to obtain another user's credentials, or failing to report suspected credential compromise.

Reporting

Suspected policy violations should be reported to the appropriate IT, Information Security, or management personnel.

Investigation

Reported violations should be reviewed and investigated based on their nature, potential impact, and applicable organisational procedures.

Disciplinary Action

Confirmed violations may result in appropriate corrective or disciplinary action in accordance with organisational policies and applicable requirements.

Violation	Example	Possible Response
Password Sharing	Giving a password to another employee	Investigation and corrective action
Unauthorized Access	Accessing information without approval	Access review and investigation

Credential Misuse	Attempting to use another user's credentials	Investigation and appropriate action
Failure to Report	Not reporting suspected credential compromise	Awareness or corrective action

GRC Relevance: Documenting policy violations establishes accountability and provides a consistent process for addressing non-compliance with security requirements.

Monitoring & Review

The organisation should monitor compliance with this policy and periodically review its effectiveness. Reviews should help identify weaknesses, outdated requirements, or changes in business and security needs.

Policy Review

This policy should be reviewed at least annually and whenever significant changes occur to the organisation's systems, business processes, security requirements, or applicable obligations.

Access Monitoring

Appropriate access and authentication activity should be monitored to identify unusual or potentially unauthorised activity.

Compliance Monitoring

Information Security and relevant system owners should monitor compliance with password and access control requirements and address identified gaps.

Policy Updates

Changes identified through reviews, security incidents, audits, or changes in business requirements should be evaluated and incorporated into the policy where appropriate.

Review Area	Frequency	Responsible Role
Policy Review	At least annually	Information Security
User Access Review	Periodically	Managers / IT
Privileged Access Review	Periodically	Information Security / IT
Compliance Review	Periodically	Information Security
Security Incident Review	As required	Information Security / IT

GRC Relevance: Monitoring and periodic review help demonstrate that security controls remain appropriate, effective, and aligned with organisational requirements.

Access Control Matrix

The Access Control Matrix defines the level of access required by different departments based on their business responsibilities. Access should be granted according to job requirements and the principles of least privilege and need to know.

Department	HR System	Finance System	IT Systems	General Applications
HR	Read/Write	No Access	Limited	Read/Write
Finance	Limited	Read/Write	Limited	Read/Write
IT	Administrative	Administrative*	Administrative	Administrative
Operations	No Access	No Access	Limited	Read/Write
Management	Read	Read	Read	Read

Access Level Legend

- Read: User can view information but cannot modify it.
- Read/Write: User can view and modify information.
- Limited: User receives only specific permissions required for their responsibilities.
- Administrative: User has elevated permissions required for authorised administrative tasks.
- No Access: User is not authorised to access the system.

GRC Relevance: The Access Control Matrix provides a structured way to document and review who should have access to specific systems. It supports authorization, least privilege, need to know, and periodic access reviews.

New Employee Access Scenario

Scenario

A new employee, Priya Shah, joins the Finance department at ABC Solutions Pvt. Ltd. Her job requires access to the Finance System and general company applications. She does not require access to HR systems or administrative IT systems.

Access Request

Priya's manager submits an access request based on her job responsibilities. The requested access is reviewed and approved before IT provisions the account.

Access Decision

System	Requested Access	Decision	Reason
Finance System	Read/Write	Approved	Required for Finance responsibilities
General Applications	Read/Write	Approved	Required for normal work activities
HR System	Read/Write	Denied	Not required for Finance responsibilities
IT Systems	Administrative	Denied	Administrative access is not required

Security Principles Applied

- Least Privilege: Priya receives only the access necessary for her job.
- Need to Know: She receives access to Finance information because it is required for her responsibilities.
- Authorization: Her manager approves the required access before it is granted.
- Segregation of Duties: The manager approves the access while IT implements the approved permissions.

GRC Relevance: This scenario demonstrates how access requests can be evaluated, approved, and implemented using defined security principles and documented access requirements.

Version History

Version	Date	Author	Changes
1.0	August 2026	Durva Amin	Initial Release

References

1. NIST. *Digital Identity Guidelines: Authentication and Lifecycle Management (SP 800-63B)*.
2. NIST. *Security and Privacy Controls for Information Systems and Organizations (SP 800-53)*.
3. Microsoft. *Microsoft Security Documentation*.
4. OWASP. *Authentication Cheat Sheet*.
5. OWASP. *Password Storage Cheat Sheet*.